

Enterprise Group Policy Baseline

ACEBUCHE.LOCAL Windows Server Lab Environment

Prepared by	Jose Antonio Acebuche
Domain	ACEBUCHE.LOCAL
Environment	Windows Server 2025 (QEMU/KVM hypervisor)
Scope	Domain-wide, Domain Controllers, and Department OUs (IT, Finance, HR, Management)
Document Type	GPO Baseline / Configuration Reference

1. Purpose & Scope

This document consolidates the enterprise-grade Group Policy Objects (GPOs) designed for the ACEBUCHE.LOCAL Active Directory environment. It is written to be reusable across organizations with minimal modification (domain name, OU paths, and file server names being the primary variables to change), consistent with the Infrastructure-as-Code approach used throughout this lab.

The AD structure referenced throughout follows a department-centric OU model: Domain > Department (IT, Finance, HR, Management) > Users / Computers / Groups. GPOs are linked at the Domain level, the Domain Controllers OU, or individual Department OUs as noted per section.

General configuration workflow (aligned to change management practice):

- Create and test in a dedicated “GPO-Testing” OU before touching production OUs.
- Create a new, purpose-specific GPO in GPMC rather than editing Default Domain Policy directly.
- Link the GPO to the test OU and verify using `gpresult /r` or `gpresult /h report.html`.
- Promote to production OUs (IT / Finance / HR / Management) only after UAT sign-off.
- Use Enforced links sparingly — only where inheritance must not be blocked by a child OU.

2. Enterprise Security & Management GPOs

2.1. Password & Account Lockout Policy

GPO Link Location	Default Domain Policy (domain-wide only — password policy cannot be applied at OU level via standard GPO)
Policy Path	Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies

Settings

- Minimum password length: 12–14 characters
- Password complexity: Enabled
- Maximum password age: 60–90 days
- Account lockout threshold: 5 invalid attempts
- Account lockout duration: 15–30 minutes

Notes

- For different password strictness per department (e.g., stricter for Finance), use a Fine-Grained Password Policy (FGPP) via Active Directory Administrative Center — this is a separate PSO mechanism, not a standard GPO.

2.2. Advanced Audit Policy Configuration

GPO Link Location	Default Domain Controllers Policy
Policy Path	Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration

Settings

- Enable: Account Logon
- Enable: Account Management
- Enable: Directory Service Access
- Enable: Logon/Logoff
- Enable: Object Access
- Enable: Policy Change

Notes

- Directly supports audit-trail requirements for account lifecycle events (e.g., disable/offboard timestamps).

2.3. Windows Firewall with Advanced Security

GPO Link Location	Per-department OU, or a dedicated “Workstation Security” OU
Policy Path	Computer Configuration > Policies > Windows Settings > Security Settings > Windows Defender Firewall with Advanced Security

Settings

- Define inbound and outbound rules per role/department
- Enforce firewall profiles: Domain, Private, Public

2.4. Restricted Groups / Local Administrator Control

GPO Link Location	IT OU, or all workstation-bearing OUs
Policy Path	Computer Configuration > Policies > Windows Settings > Security Settings > Restricted Groups

Settings

- Add FS_IT_FullControl (or dedicated admin group) to the local “Administrators” group
- Ensures controlled, auditable assignment of local admin rights

2.5. Software Restriction / AppLocker

GPO Link Location	Per department — stricter for Finance/HR, more relaxed for IT
Policy Path	Computer Configuration > Policies > Windows Settings > Security Settings > Application Control Policies > AppLocker

Settings

- Executable rules
- Windows Installer rules
- Script rules

Notes

- Publisher-based rules are more maintainable long-term than path-based rules.

2.6. Screen Lock / Inactivity Timeout

GPO Link Location	User Configuration, applied per department OU
Policy Path	User Configuration > Policies > Administrative Templates > Control Panel > Personalization

Settings

- Enable screen saver
- Password protect the screen saver
- Screen saver timeout: 900 seconds (15 minutes)

2.7. USB / Removable Storage Restriction

GPO Link Location	Finance and HR OUs (higher-sensitivity data)
Policy Path	Computer Configuration > Policies > Administrative Templates > System > Removable Storage Access

Settings

- “All Removable Storage: Deny all access” — or restrict write access only, depending on business need

2.8. Windows Update Management (WSUS-integrated)

GPO Link Location	Domain-wide, or per OU for staggered/phased deployment
Policy Path	Computer Configuration > Policies > Administrative Templates > Windows Components > Windows Update

Settings

- Point clients to the internal WSUS server
- Configure auto-download / auto-install schedule

2.9. Event Log Retention & Size

GPO Link Location	Domain Controllers Policy, plus workstation OUs
Policy Path	Computer Configuration > Policies > Administrative Templates > Windows Components > Event Log Service

Settings

- Maximum log size: 196608 KB (adjust per storage capacity)
- Retention method configured per compliance/audit needs

2.10. Folder Redirection + Offline Files

GPO Link Location	Per department OU (for roaming/hot-desk users)
Policy Path	User Configuration > Policies > Windows Settings > Folder Redirection

Settings

- Redirect Documents and Desktop to the file server share (e.g., \\FS01\UserData\$\%username%)
- Pairs with the File Server NTFS/share permission structure already in place

3. Roaming User Profiles — “Log in on Any PC, Same Profile”

Roaming User Profiles allow a user's desktop, settings, and profile data to follow them to any domain-joined PC. This is an Active Directory user attribute (ProfilePath), not a GPO by itself — but it is paired with GPO settings below to keep it performant and secure. Ideal for hot-desking or shared-workstation environments.

3.1 Create the Profile Share on the File Server

```
New-Item -Path "D:\Shares\Profiles" -ItemType Directory
New-SmbShare -Name "Profiles$" -Path "D:\Shares\Profiles" `
-FullAccess "ACEBUCHE\Domain Admins" -ChangeAccess "Everyone"
```

Use a trailing \$ (Profiles\$) to create a hidden share — it will not appear in normal network browsing.

3.2 NTFS Permissions

- Remove inherited permissions from the Profiles root folder
- SYSTEM = Full Control
- Domain Admins = Full Control
- Authenticated Users = “List folder contents” only on the root (allows users to create their own subfolder without reading others')

3.3 Configure Profile Path (Active Directory Users and Computers)

Set on the Profile tab of the user object:

```
\\FS01\Profiles$\%username%
```

3.4 Bulk Apply via PowerShell

```
Get-ADUser -Filter {Department -eq "IT"} | ForEach-Object {
    Set-ADUser $_ -ProfilePath "\\FS01\Profiles$\($_.SamAccountName)"
}
```

Adapt the -Filter value per department (Finance, HR, Management) to roll this out org-wide.

3.5 Supporting GPO — Folder Redirection (Recommended)

Roaming profiles work without this GPO, but pairing it in prevents large Desktop/Documents folders from bloating the profile and slowing logins/logouts.

GPO Link Location	Per department OU
Policy Path	User Configuration > Policies > Windows Settings > Folder Redirection

- Redirect Desktop, Documents, and Downloads to \\FS01\UserData\$\%username%\<folder>
- Redirected folders are excluded from the roaming profile copy, reducing login/logout time

3.6 Supporting GPO — Roaming Profile Optimization

GPO Link Location	Domain-wide or per OU
Policy Path	Computer Configuration > Policies > Administrative Templates > System > User Profiles

- “Delete cached copies of roaming profiles” → Enabled (prevents leftover local profile buildup on every PC)
- “Only allow local user profiles” → Must remain Not Configured / Disabled (enabling this breaks roaming entirely)
- “Background upload of a roaming user profile’s registry file” → Enabled (proactive backup)

3.7 Important Cautions

- Profile size matters — large Desktop contents slow down login/logout; pair with Folder Redirection (3.5).
- Keep OS versions consistent across PCs (e.g., all Windows 11) — profile format differs across major Windows versions.
- Roaming Profiles ≠ Mandatory Profiles. A Mandatory Profile (NTUSER.DAT renamed to NTUSER.MAN) resets on every logout and is used for locked-down kiosk/lab PCs — different use case, different setup.

4. Reusability Notes (Infrastructure-as-Code Adaptation)

To deploy this baseline in a different organization, only the following values typically need to change:

- Domain name (ACEBUCHE.LOCAL → target domain)
- Department/OU names and structure
- File server name and share paths (FS01, Profiles\$, UserData\$)
- Security group names (FS_IT_FullControl, FS_IT_ReadOnly, etc.)
- Password/lockout thresholds and audit retention values, per organizational security policy